

МАША: серверный доступ, оплата и реклама

Технический план v10 - 27.08.2026

Главный принцип: без подтверждения сервера нельзя начать ни обычный, ни Direct IP-сеанс. Клиент бесплатный. Право оператора определяется единым Access / Entitlement Engine.

Участник	Действие	Обязательная проверка
Клиент	Публикует ID и heartbeat	Состояние устройства и привязка к сеансу
Оператор	Передаёт Device Key и ID клиента	Право доступа, лимиты, блокировки
Сервер Маши	Выдаёт session ticket и короткую lease	Подпись, срок, nonce, jti, binding
Принимающая Маша	Проверяет ticket до соединения	Тот же контроль для P2P, relay и Direct IP

Разрешено: сервер выдаёт короткоживущий подписанный ticket. После установления соединения сервер выдаёт и продлевает lease через heartbeat.

Не разрешено: новый сеанс не начинается. Если lease активного сеанса не продлена, сеанс завершается после установленного grace period.

Источники права

`payment`, `ad_reward`, `trial`, `promo` и `admin` создают унифицированные `access_grants`. Состояние оплаты не равно итоговому состоянию доступа.

Реклама как канал получения права

Приложение не может самостоятельно заявить `ad_watched=true`. Сервер создаёт одноразовый `offer/nonce`. Награда начисляется только после server-to-server webhook рекламной сети либо после серверной проверки `receipt/token`.

1. Обязательная модель авторизации

1.1. Решение сервера и fail-closed

- Любой новый сеанс вызывает `POST /v1/session/authorize`.
- Если сервер авторизации недоступен или ответ нельзя проверить, новый сеанс запрещён.
- Путь трафика не влияет на правило: P2P, relay и Direct IP используют одну авторизацию.
- Принимающее приложение проверяет подпись, срок и привязку права к конкретному сеансу.

1.2. Обязательные поля session ticket

Поле	Назначение
operator_device_id	Разрешённый экземпляр операторской Маши
client_id	Конкретное принимающее устройство
session_id	Конкретный сеанс
nonce, jti	Одноразовость и защита от повторного использования
iat, nbf, exp	Время выдачи, начала действия и окончания
kid	Ключ подписи и его ротация
constraints	Режим, лимиты, версия протокола и иные ограничения

1.3. Защита от повторного использования

`jti` регистрируется сервером и принимающей стороной. Ticket действует только для пары `operator-device/client`, конкретного `session_id` и `nonce` рукопожатия. Повторный ticket, другая цель или изменённые параметры отклоняются.

1.4. Lease активного сеанса

- После старта сервер создаёт короткую lease; приложение продлевает её heartbeat-запросами.
- Блокировка, отзыв права или исчерпание лимита запрещают продление.
- После пропуска heartbeat действует короткий серверный grace period, затем сеанс завершается.
- Точные интервалы heartbeat, TTL ticket и grace period являются серверными параметрами.

2. Данные, события и API

2.1. Основные таблицы

Таблица	Содержание
operators, devices	Device Key, состояние экземпляра, версия, блокировка
access_policies	Правила тарифа, группы и оператора
access_grants	Источник, тип, объём, valid_from, valid_until, статус
grant_consumption	Резервирование и списание права по сеансам
usage_sessions	authorize, start, heartbeat, finish, серверная длительность
session_tickets	jti, session_id, bindings, срок, состояние использования
billing_accounts	Расчётный статус отдельно от права доступа
payment_events	Исходные webhook-события и результат обработки
ad_reward_events	Provider, offer/nonce, receipt, награда, уникальность
audit_log	Решения доступа, отказы, блокировки и административные действия

2.2. Идемпотентность и доверие к событиям

- Каждый платёжный и рекламный webhook имеет уникальный provider event ID.
- Подпись провайдера проверяется до изменения состояния.
- Повторная доставка не создаёт повторный grant или повторное начисление.
- Сохраняются исходное событие, время получения, результат проверки и связь с созданным grant.

2.3. Основные API

- POST /v1/session/authorize - решение и выдача ticket.
- POST /v1/sessions/start , /heartbeat , /finish - lease, время и списание.
- GET /v1/access/status - итоговый доступ, причина и варианты восстановления.
- POST /v1/payments/create , POST /v1/webhooks/yookassa .
- GET /v1/ad-rewards/offers , POST /v1/ad-rewards/prepare .
- POST /v1/webhooks/ad/{provider} , POST /v1/ad-rewards/claim .

2.4. Учёт времени

Время услуги - период установленного сеанса удалённого управления от подтверждённого start до finish либо серверного закрытия после пропажи heartbeat. Сервер задаёт округление, минимальную единицу, правила аварийного завершения и одновременных сеансов. Повторные запросы не увеличивают время и списание.

Проверяемый план реализации

ЭТАП 1 ЗАВЕРШЁН

desktop → local-server подтверждено; этапы 1.0–1.8 закрыты.

ТЕКУЩИЙ ЭТАП: 2.0 — СЕРВЕРНАЯ ПОСТОПЛАТА

Тариф 1 Р/час активного управления; источник истины — сервер.

Подтверждённые результаты

- Git: 7c9bda7d0; Windows x64 и CI проходят; 12 из 12 серверных проверок успешны.
- Сеанс через rendezvous 77.222.38.70:21116 и relay :21117; H264, стабильные 30 FPS.

Статус этапов 1.0–1.8

1.0	CI и Windows-сборка	ЗАВЕРШЁН
1.1	Базовое серверное управление	ЗАВЕРШЁН
1.2	Внешний deny до relay	ЗАВЕРШЁН
1.3	Подпись, попсо и защита от повторов	ЗАВЕРШЁН
1.4	Fail-closed и совместимость протокола	ЗАВЕРШЁН
1.5	Управление доступом оператора	ЗАВЕРШЁН
1.6	Стабильность rendezvous/relay	ЗАВЕРШЁН
1.7	Подготовка рабочего контура	ЗАВЕРШЁН
1.8	Реальное desktop → local-server	ЗАВЕРШЁН

P0 — ПОСТОЯННЫЙ ПАРОЛЬ И СОХРАНЁННЫЕ ДАННЫЕ

ДО ПУБЛИЧНОЙ РАЗДАЧИ

- ошибка «Неправильный пароль» отключает повторную отправку сохранённого пароля;
- кнопка «Повтор» открывает пустое поле ввода; доступна команда «Забыть пароль»;
- новый пароль сохраняется только после успешного входа и явного согласия;
- хранение — Windows Credential Manager; пароля нет в peer TOML.

Приёмка: после отказа новый пароль вводится без редактирования файлов.

Критерий готовности этапа 2.0

- 1 час подтверждённой активности = ровно 1 Р; повторный finish не создаёт долг;
- просрочка без grant блокирует новый сеанс; ad_reward, promo и admin сохраняют доступ;
- предупреждение формируется за 10 минут до блокировки.

4. Обязательные приёмочные тесты этапа 1

1. **Active:** действующее право - сеанс разрешён.
2. **Blocked / expired:** новое соединение запрещено.
3. **Fail-closed:** сервер авторизации недоступен - новое соединение запрещено.
4. **Direct IP:** без действующего ticket соединение запрещено.
5. **Replay:** повторное использование ticket или jti запрещено.
6. **Wrong binding:** ticket другого клиента, оператора или session_id запрещён.
7. **Tamper:** изменение полей или подписи приводит к отказу.
8. **Lease revoke:** отзыв права прекращает активный сеанс после grace period.
9. **Heartbeat loss:** пропажа heartbeat закрывает сеанс и фиксирует серверную длительность.
10. **Idempotency:** повторные start/finish/webhook не создают двойного списания или grant.
11. **Alternative grant:** payment overdue не блокирует действующий ad_reward, promo или admin grant.
12. **Concurrent sessions:** сервер применяет заданный лимит одновременных сеансов.

Не входит в этап 1

Редизайн интерфейса, installer/auto-update, YooKassa UI, рекламный UI, защита бинарника и сайт не должны задерживать подтверждение серверного контроля. Их реализация начинается после прохождения тестов 1-12.

Порядок доказательства результата

- Коммит и точный SHA в репозитории на `server`.
- Лог автоматических тестов.
- Успешная Windows x64 сборка.
- Протокол ручного теста на операторском и клиентском устройствах.

Порядок коммерциализации

ПРИНЦИП

Сначала серверный учёт права доступа и долга; затем платёжный провайдер и альтернативные способы доступа.

2.0

Серверная постоплата

ТЕКУЩИЙ

Тариф 1 ₽/час, server-only duration, debt, due/grace, T-10, /v1/access/status, идемпотентность.

2.1

ЮKassa

СЛЕДУЮЩИЙ

Создание платежа, webhook, сверка статуса и закрытие задолженности.

2.2

Rewarded-реклама

ПОСЛЕ 2.1

Grant ad_reward с серверным сроком действия; без обхода платёжных правил.

2.3

Установщик и автообновление

ПОСЛЕ БИЛЛИНГА

Подписанный установщик, проверяемое обновление, контролируемый откат.

2.4

Защита бинарей

ПЕРЕД ПУБЛИКАЦИЕЙ

Подпись, контроль целостности и базовое усложнение подмены клиента.

2.5

Интерфейс и бренд

ПЕРЕД ПИЛОТОМ

Понятные статусы доступа, долга, предупреждения и оплаты.

2.6

Сайт и выпуск

ФИНАЛ

Тарифы, документы, загрузка, поддержка и публичный контур.

Ближайшая контрольная точка

Этап 2.0 принят только после автоматических тестов правил начисления и блокировки.